Atomic Red Team: Emulação de Adversários

O **Atomic Red Team** é um framework de código aberto (mantido pela Red Canary) que permite testar defesas através de pequenas simulações de ataque chamadas "Atomics". Cada teste é mapeado diretamente para uma técnica do framework **MITRE ATT&CK**.

1. Por que o ART é essencial?

- **Modularidade:** Você testa uma técnica específica (ex: Escalonamento de Privilégio) sem precisar rodar um ataque completo e complexo.
- **Plataformas:** Suporta Windows, Linux, macOS e ambientes de Cloud (AWS, Azure, GCP).
- **Foco em Detecção:** O objetivo não é apenas "atacar", mas sim gerar os logs necessários para validar se o seu SIEM/EDR está disparando alertas.

2. Anatomia de um Teste Atômico

Cada teste é estruturado em arquivos **YAML** e **Markdown**, contendo:

- **Executores:** Os "motores" que rodam o comando (sh/bash, cmd.exe, powershell.exe).
- **Dependências:** Comandos para verificar e baixar as ferramentas necessárias antes do teste.
- **Input Arguments:** Variáveis personalizáveis (ex: o caminho onde um arquivo de log será salvo).
- **Cleanup:** Comandos para apagar vestígios e retornar o sistema ao estado original (essencial para manter a integridade do ambiente).

Exemplo Prático: T1003.001 (LSASS Memory Dump)

Um dos testes mais comuns simula o roubo de credenciais da memória do Windows usando a ferramenta **ProcDump** da Sysinternals:

1. **Comando:** procdump.exe -ma lsass.exe output.dmp
2. **O que o Blue Team deve ver:** Um processo suspeito acessando a memória do lsass.exe.
3. **Cleanup:** O arquivo .dmp é deletado automaticamente após o teste.
4.

Emulação de Ameaças: Invoke-AtomicRedTeam

O **Invoke-AtomicTest** é o principal motor para carregar, validar e executar testes atômicos baseados no framework **MITRE ATT&CK**. Esta documentação foca na operação técnica do módulo e na validação de artefatos em ambiente Windows.

Guia de Operação

Para garantir a segurança do host e a visibilidade dos testes, seguimos o fluxo padrão:

1. **Inspeção:** Uso de `-ShowDetailsBrief` e `-ShowDetails` para análise do código antes da execução.
2. **Pré-requisitos:** Uso de `-CheckPrereqs` e `-GetPrereqs` para garantir que os binários de ataque estejam presentes.
3. **Execução:** Filtragem granular por `-TestNumbers` ou `-TestGuids`.
4. **Limpeza:** Uso obrigatório de **`-Cleanup`** para remover IoCs (Indicadores de Comprometimento) após a validação.

Laboratório Prático: Questões e Evidências

Abaixo estão as métricas e artefatos coletados durante o exercício de emulação.

1. Execução via Proxy - LOLBins (T1218.005)

- **Pergunta:** Qual é o nome atômico do segundo teste sob o número atômico T1218.005?
- **Resposta: Mshta.exe executing VBScript to command execution**.

```
PS C:\Users\Administrator> Invoke-AtomicTest T1218.005-2
PathToAtomicsFolder = C:\Tools\AtomicRedTeam\atomics

Executing test: T1218.005-2 Mshta executes VBScript to execute malicious command
Done executing test: T1218.005-2 Mshta executes VBScript to execute malicious command
```

2. Persistência via Agendador de Tarefas (T1053.005)

- **Pergunta:** Qual o nome da tarefa agendada criada após a execução do segundo teste?
- **comando:** Invoke-AtomicTest T1053.005 -ShowDetails
- **Resposta: spawn**

```
[********BEGIN TEST*******]
Technique: Scheduled Task/Job: Scheduled Task T1053.005
Atomic Test Name: Scheduled task Local
Atomic Test Number: 2
Atomic Test GUID: 42f53695-ad4a-4546-abb6-7d837f644a71
Description: Upon successful execution, cmd.exe will create a scheduled task to spawn cmd.exe at 20:10.

Attack Commands:
Executor: command_prompt
ElevationRequired: False
Command:
SCHTASKS /Create /SC ONCE /TN spawn /TR #{task_command} /ST #{time}
Command (with inputs):
SCHTASKS /Create /SC ONCE /TN spawn /TR C:\windows\system32\cmd.exe /ST 20:10
```

3. Persistência via Registro do Windows (T1547.001)

- **Pergunta:** Qual é a chave de registro modificada após a execução do segundo teste?
- **Resposta: HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\RunOnceEx\0001\Depend**.

```
Attack Commands:
Executor: command_prompt
ElevationRequired: True
Command:
REG ADD HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\RunOnceEx\0001\Depend /v 1 /d "#{thing_to_execute}"
Command (with inputs):
REG ADD HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\RunOnceEx\0001\Depend /v 1 /d "C:\Path\AtomicRedTeam.dll"

Cleanup Commands:
Command:
REG DELETE HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\RunOnceEx\0001\Depend /v 1 /f >nul 2>&1
[!!!!!!!!END TEST!!!!!!!]
```

Conclusão: Higiene Pós-Ataque

Após a coleta das evidências acima, foi executado o comando:
`Invoke-AtomicTest <Técnica> -Cleanup`

Esta etapa é inegociável em operações de Red Team e Emulação, garantindo que o sistema retorne ao seu estado íntegro e que ferramentas de teste não permaneçam no ambiente como potenciais vulnerabilidades (**Shadow IT**).

Emulação de Adversários: Grupo admin@338

Nesta etapa, elevamos o nível da operação saindo de testes isolados para uma **Emulação Baseada em Adversários**. Utilizamos o **ATT&CK Navigator** para

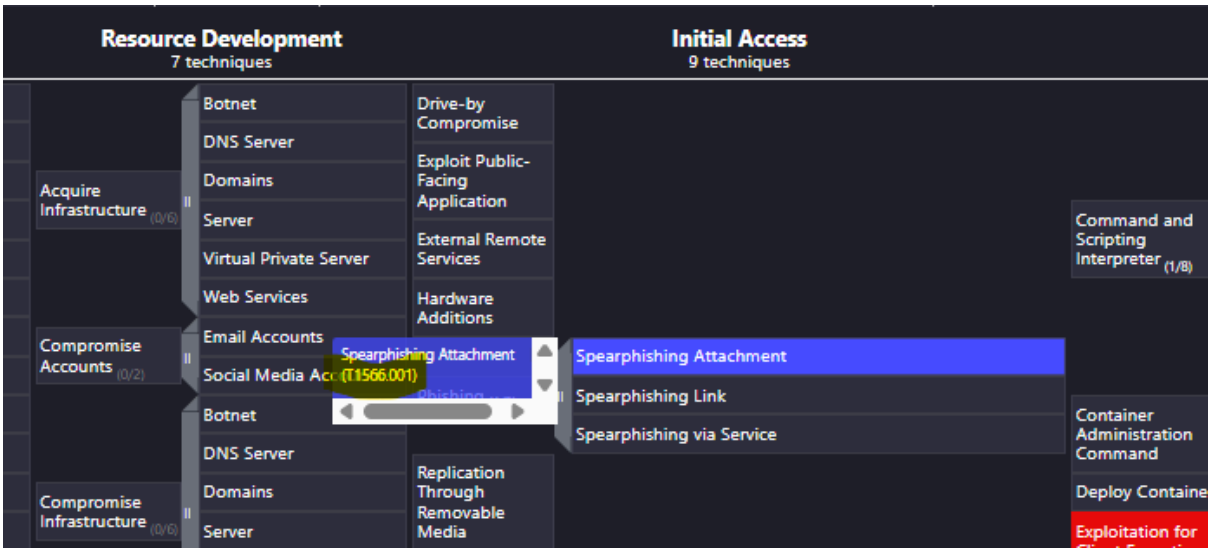
mapear o comportamento do grupo de ameaça **admin@338** e replicar suas TTPs (Táticas, Técnicas e Procedimentos) no ambiente.

Mapeamento com ATT&CK Navigator

Abaixo, a validação das técnicas identificadas na matriz e a conferência de disponibilidade no framework Atomic Red Team.

Questão 01: Identificação do Vetor de Ataque

- **Pergunta:** Utilizando o mapeamento fornecido pelo ATT&CK Navigator, qual é o ID da técnica de phishing usada pelo grupo de ameaças?
- **Resposta: T1566.001** (Spearphishing Attachment).



Questão 02: Inventário de Testes (Discovery)

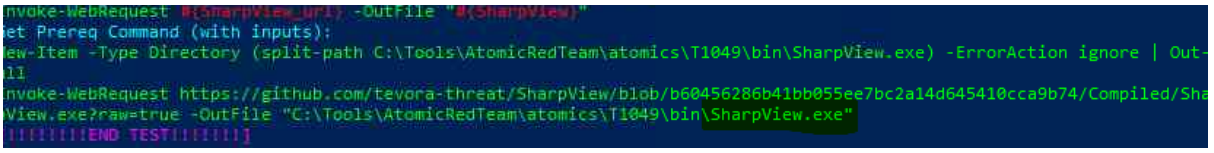
- **Pergunta:** Quantos testes atômicos no Atomic T1083 (File and Directory Discovery) são suportados em hosts Windows?
- **Resposta:** 4
- **Comando:** `Invoke-AtomicTest T1083 -ShowDetailsBrief`

```
PS C:\Users\Administrator> Invoke-AtomicTest T1083 -ShowDetailsBrief
PathToAtomicsFolder = C:\Tools\AtomicRedTeam\atomics

T1083-1 File and Directory Discovery (cmd.exe)
T1083-2 File and Directory Discovery (PowerShell)
T1083-5 Simulating MAZE Directory Enumeration
T1083-6 Launch DirLister Executable
```

Questão 03: Análise de Dependências (T1049)

- **Pergunta:** Que arquivo deve existir para satisfazer o pré-requisito do Teste Atômico T1049-4?
- **Resposta:** Sharpview.exe
- **Comando:** `Invoke-AtomicTest T1049-4 -ShowDetails`

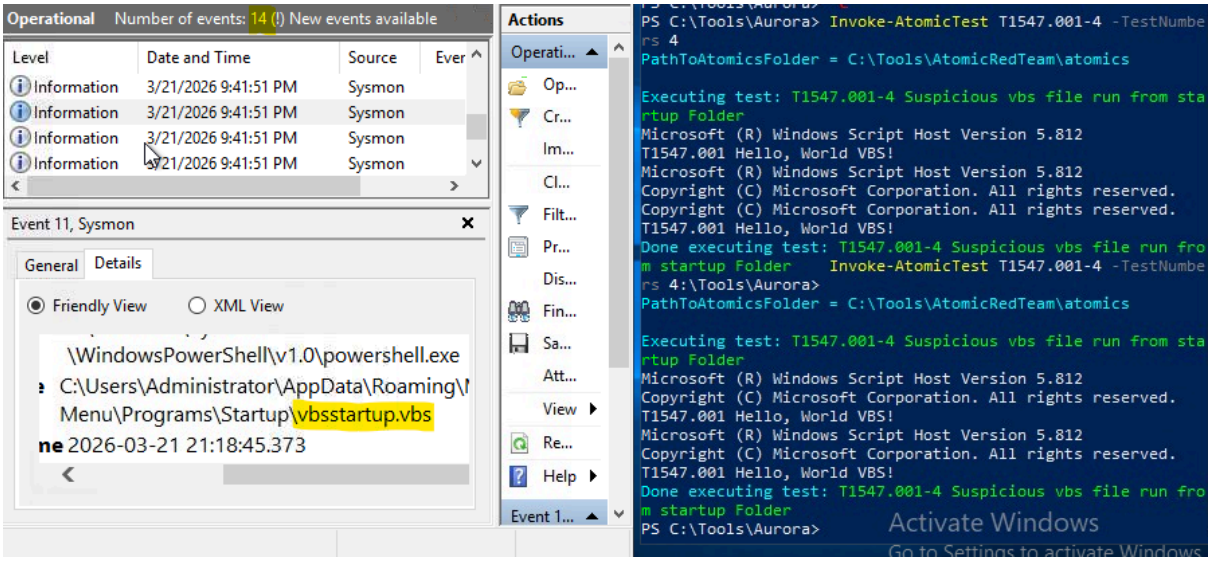


Validação de Telemetria (Blue Team)

Nesta etapa, validamos a visibilidade das ferramentas de defesa (**Sysmon** e **Aurora EDR**) contra técnicas de persistência.

Caso 01: Persistência via Pasta de Inicialização (T1547.001-4)

- **Detecção:** Identificado evento de criação de arquivo (**Sysmon ID 11**).
- **Artefato:** Arquivo `vbsstartup.vbs` criado na pasta Startup do usuário.



Caso 02: Modificação de Políticas de Registro (T1547.001-13)

- **Detecção:** Identificado evento de modificação de registro (**Sysmon ID 13**).
- **TargetObject:** `HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explorer\Run\atomictest`

- **Análise:** O uso de chaves de política (`Policies\Explorer\Run`) é uma tática astuta, pois muitas ferramentas de monitoramento focam apenas nas chaves de Run padrão.

Caso 03: Detecção via Aurora EDR (Sigma)

- **Observação:** Durante a execução do teste **T1547.001-2 (RunOnce)**, o Aurora EDR disparou alertas baseados em regras **Sigma**, correlacionando a modificação do registro com comportamentos de adversários conhecidos.

Customização e Criação de Testes Atômicos

Nem toda organização é igual. Diferentes políticas de segurança, sistemas legados ou configurações de rede exigem que a emulação de adversários seja adaptável. O framework Atomic Red Team oferece dois caminhos para isso: **Argumentos de Entrada** e o **Atomic GUI**.

1. Argumentos de Entrada Personalizados (`-InputArgs`)

Muitos Atomics possuem variáveis definidas no campo `input_arguments`. Isso permite alterar o comportamento do teste sem modificar o código-fonte (YAML).

- **Prompt Interativo:** O parâmetro `-PromptForInputArgs` faz o PowerShell perguntar os valores em tempo real.
- **Tabela Hash:** O parâmetro `-InputArgs` permite passar um objeto com os valores prontos.

Exemplo Prático: Técnica T1136.001 (Criar Conta Local)

Ao enfrentar uma política de complexidade de senha, podemos sobrescrever os valores padrão:

PowerShell
```
$customArgs = @{ "username" = "THM_Atomic"; "password" = "p@ssw0rd123!" }
Invoke-AtomicTest T1136.001 -TestNumbers 3 -InputArgs $customArgs
```

Nota importante: Ao executar o `-Cleanup`, você deve passar os mesmos argumentos customizados para que o script saiba exatamente qual usuário ou arquivo deve remover.

2. Criação de Novos Testes: Atomic GUI

Para técnicas que ainda não possuem um Atomic ou para casos de uso extremamente específicos, utilizamos o **Atomic GUI**, uma interface visual que gera o código YAML necessário.

Fluxo de Trabalho no Atomic GUI:

1. **Inicialização:** Execute `Start-AtomicGui` no PowerShell e acesse `http://localhost:8487`.
2. **Preenchimento:** Insira o nome do teste, comandos de ataque e, crucialmente, os **comandos de limpeza**.
3. **Geração:** Clique em "GERAR DEFINIÇÃO DE TESTE".
4. **Implementação:** O YAML gerado deve ser colado no arquivo `.yaml` da técnica correspondente dentro da pasta `atomics`.

Estudo de Caso: Emulação do Grupo APT37 (Reaper)

O **APT37** é um grupo de ciberespionagem de origem norte-coreana, ativo desde 2012. Seu foco principal é a exfiltração de dados de setores governamentais e de defesa. Nesta atividade, realizamos o ciclo completo de emulação para validar nossas defesas contra este adversário específico.

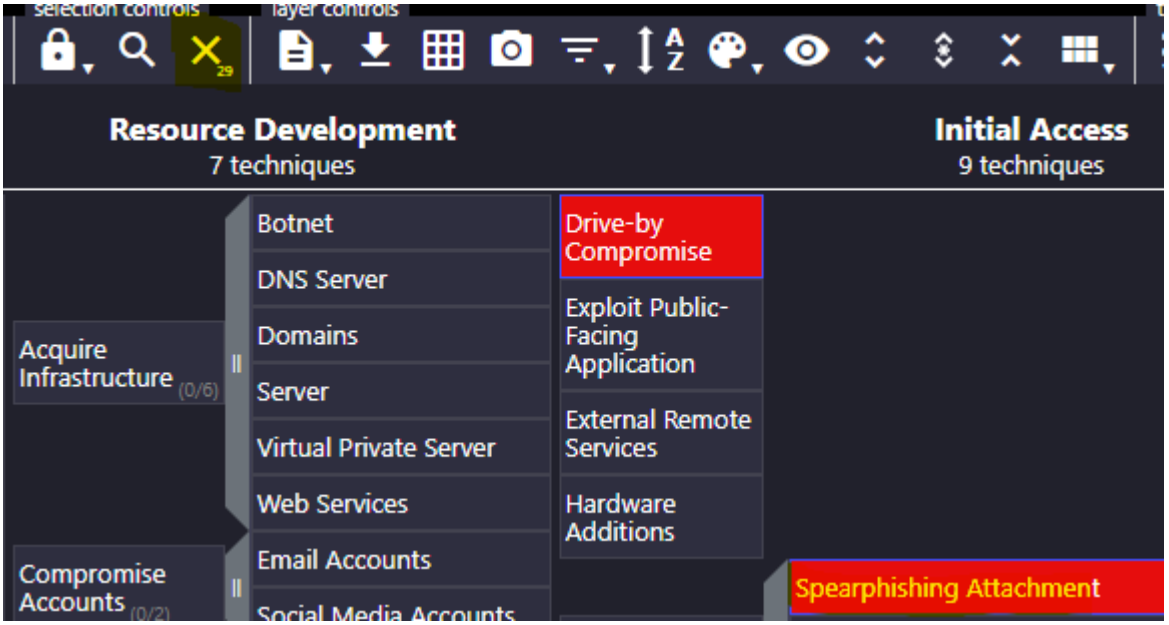
1. Inteligência de Ameaças (Mapeamento)

Utilizamos o **ATT&CK Navigator** para extrair o perfil operacional do grupo. O mapeamento permite focar apenas nas técnicas que o APT37 realmente utiliza, otimizando o tempo do Red Team.

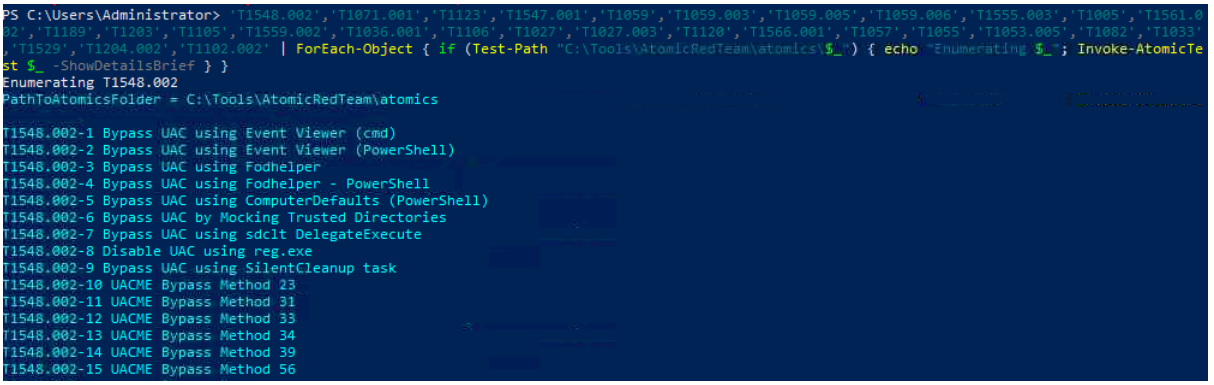
Questões de Inteligência

- **Pergunta:** Usando o ATT&CK Navigator, quantas técnicas são atribuídas ao APT37?
- **Resposta: 29**

- **Pergunta:** Qual é a técnica de phishing usada pelo grupo de ameaças?
  Resposta: Spearphishing Attachment (T1566.001).



- **Pergunta:** Quantas técnicas atribuídas ao APT37 possuem um arquivo Atomic existente?
- **Resposta: 21**



2. Preparação e Pré-requisitos

Antes da execução, validamos a compatibilidade dos testes com o nosso sistema operacional Windows.

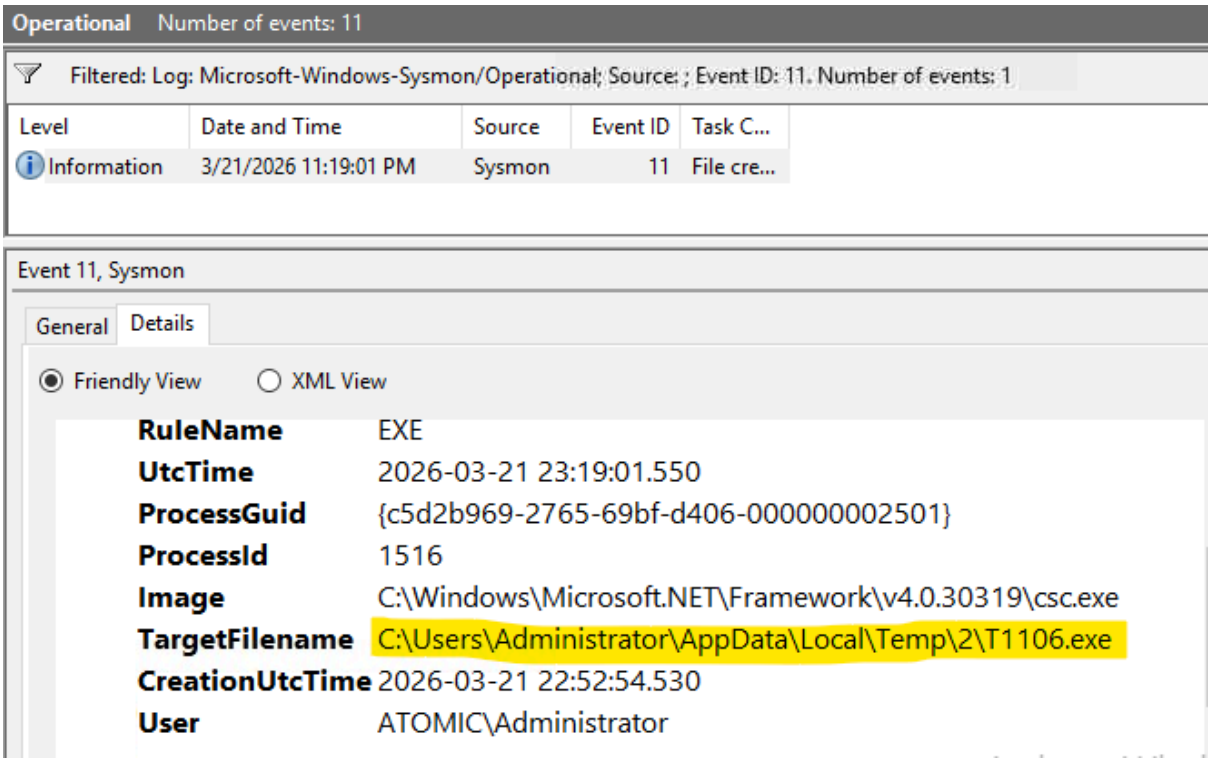
- **Pergunta:** Qual versão do Atomic (Técnica) não possui testes suportados no Windows?
- **Resposta: T1059.006**
- **Pergunta:** Qual é a descrição do pré-requisito necessário para o Teste Atômico T1055-1?
- **Resposta: The 64-bit version of Microsoft Office must be installed**
- **Pergunta:** Quantos testes atômicos atenderam aos pré-requisitos para o teste atômico T1082?

- **Resposta: 15**

```
PS C:\Users\Administrator>  Invoke-AtomicTest T1082 -CheckPrereqs
PathToAtomicsFolder = C:\Tools\AtomicRedTeam\atomics

CheckPrereq's for: T1082-1 System Information Discovery
Prerequisites met: T1082-1 System Information Discovery
CheckPrereq's for: T1082-6 Hostname Discovery (Windows)
Prerequisites met: T1082-6 Hostname Discovery (Windows)
CheckPrereq's for: T1082-8 Windows MachineGUID Discovery
Prerequisites met: T1082-8 Windows MachineGUID Discovery
CheckPrereq's for: T1082-9 Griffon Recon
Prerequisites met: T1082-9 Griffon Recon
CheckPrereq's for: T1082-10 Environment variables discovery on windows
Prerequisites met: T1082-10 Environment variables discovery on windows
CheckPrereq's for: T1082-13 WinPwn - winPEAS
Prerequisites met: T1082-13 WinPwn - winPEAS
CheckPrereq's for: T1082-14 WinPwn - itm4nprivesc
Prerequisites met: T1082-14 WinPwn - itm4nprivesc
CheckPrereq's for: T1082-15 WinPwn - Powersploits privesc checks
Prerequisites met: T1082-15 WinPwn - Powersploits privesc checks
CheckPrereq's for: T1082-16 WinPwn - General privesc checks
Prerequisites met: T1082-16 WinPwn - General privesc checks
CheckPrereq's for: T1082-17 WinPwn - GeneralRecon
Prerequisites met: T1082-17 WinPwn - GeneralRecon
CheckPrereq's for: T1082-18 WinPwn - Morerecon
Prerequisites met: T1082-18 WinPwn - Morerecon
CheckPrereq's for: T1082-19 WinPwn - RBCD-Check
Prerequisites met: T1082-19 WinPwn - RBCD-Check
CheckPrereq's for: T1082-20 WinPwn - PowerSharpPack - Watson searching for missing windows pa
Prerequisites met: T1082-20 WinPwn - PowerSharpPack - Watson searching for missing windows pa
CheckPrereq's for: T1082-21 WinPwn - PowerSharpPack - Sharpup checking common Privesc vectors
Prerequisites met: T1082-21 WinPwn - PowerSharpPack - Sharpup checking common Privesc vectors
CheckPrereq's for: T1082-22 WinPwn - PowerSharpPack - Seatbelt
Prerequisites met: T1082-22 WinPwn - PowerSharpPack - Seatbelt
CheckPrereq's for: T1082-23 Azure Security Scan with SkyArk
```

3. Telemetria e Análise de Logs

A parte mais crítica: observar o que o **Sysmon** e o **Aurora EDR** capturaram durante a simulação das técnicas de execução e persistência.

- **Pergunta:** Quais são os três IDs de evento registrados com base na execução do Teste Atômico 1547.001-3?
- **Resposta: 1, 11, 13**
- **Pergunta:** Qual comando é executado (com o valor de entrada padrão) pelo Teste Atômico T1529-1?
- **Resposta: shutdown /s /t 1**
- **Pergunta:** Qual é o valor do TargetFilename no log de criação de arquivo (ID 11) gerado pelo teste T1106-1?
- **Resposta: C:\Users\Administrator\AppData\Local\Temp\2\T1106.exe**